Day 25: Brute-Force Style Detection Simulation

Controlled Failed-Logon Sequence, Telemetry Analysis, and Escalation Decision

SOC Internship - TriosCyber

Field	Details
Intern Name	Amrita Pathak
Date	29 September 2026
Internship Track	SOC (Security Operations Center)
Assigned Task	Generate repeated safe authentication failures against your own lab account at a controlled pace. Investigate the resulting telemetry, count the attempts, and determine whether the pattern should be escalated. (Tools: Wazuh, Event Viewer/journalctl)
Status of this Report	**Practical exercise, fully completed on the Windows side. Eight controlled failed logon attempts and one successful logon were generated against the CyberAmy lab account and independently verified in Event Viewer, with real timestamps used throughout this report. The Wazuh-side confirmation (whether this pattern would generate a correlated alert) is applied theoretically, using Wazuh's real, previously-verified rule 60204 logic from Day 21, since a Wazuh manager is not yet deployed in this lab (see Days 17-20). It will be confirmed against a live alert once a manager is available.**

Table of Contents

Table of Contents 2
Key Terms 3
Important Note on This Report 3
Executive Summary 4
1. Objective 5
2. Safety Precheck: Account Lockout Policy 5
3. Test Execution 6
4. Investigating the Telemetry 6
5. Locating the Successful Logon - A Methodology Note 8
6. Applying Wazuh's Real Correlation Rule to This Data 11
7. Escalation Decision 11
8. Evidence Summary 12
9. Conclusion 12

Key Terms

- **Threshold-Based Correlation:** Wazuh's method of distinguishing a single, low-severity event from an actual attack pattern: watching for a rule (or rule group) to match a set number of times within a set time window before escalating to a higher-severity alert.
- **Lockout Threshold:** A Windows account-policy setting that automatically locks an account after a defined number of failed logon attempts within an observation window, for a defined duration; checked here before testing to avoid accidentally locking the test account.
- **Subject vs. New Logon:** Two separate account fields present in every Windows Event ID 4624 (successful logon). Subject identifies the process or account that performed the logon operation (frequently SYSTEM or the machine account itself for an interactive logon), while New Logon identifies who actually logged in; confusing the two was a real methodology lesson encountered directly during this exercise, documented in Section 4.
- **Elapsed Window:** The total time between the first and last event in a sequence being analyzed; the figure a correlation rule's timeframe attribute is actually measured against.
- **Benign True Positive:** A case where a detection rule correctly and legitimately fires, because the observed pattern genuinely matches its signature, but investigation determines the underlying activity was not malicious; distinct from a false positive, where the rule should not have fired at all.

Important Note on This Report

Unlike the majority of this report series, the core evidence in this report is real, not illustrative: all eight failed logons and the successful logon that followed were genuinely generated during this session and independently verified in Event Viewer, with real timestamps used throughout. Only the final confirmation step, whether Wazuh's manager would have actually raised a correlated alert, is theoretical, because no Wazuh manager is deployed in this lab (see Days 17-20). That theoretical step applies Wazuh's real rule 60204 definition, already verified against Wazuh's public ruleset in the Day 21 report, to this session's genuine data.

Executive Summary

Day 25 asks for a controlled sequence of authentication failures to be generated against a real lab account, for the resulting telemetry to be investigated and counted, and for a reasoned escalation decision to be made. This was carried out practically in full on the Windows side: eight failed logon attempts were made against the CyberAmy account at a controlled pace of roughly 25-40 seconds apart, followed by one successful logon, all independently located and verified in Event Viewer.

Before testing began, the account's lockout policy was checked (net accounts), confirming a 10-attempt lockout threshold; eight attempts was chosen deliberately to stay safely under that ceiling while also aligning with Wazuh's own real brute-force correlation threshold of 8 occurrences within 240 seconds, so the exercise would produce a result that is actually meaningful to evaluate against a real detection rule, not an arbitrary count.

The eight failures spanned 226 seconds start to finish, inside Wazuh's 240-second correlation window, meaning this exact pattern would have crossed the real brute-force alert threshold on a live system. This report's conclusion is that the pattern should be escalated on its rule-based merits, while also explaining why, once investigated, it resolves as a benign true positive rather than an active compromise, since the source, account owner, and eventual success are all already known and self-attributable in this lab context.

1. Objective

Generate a controlled sequence of failed authentication attempts against a lab account, verify and count the resulting telemetry in Event Viewer, apply Wazuh's real correlation logic to determine whether the pattern crosses a genuine brute-force threshold, and reach a reasoned escalation decision rather than a purely mechanical one.

2. Safety Precheck: Account Lockout Policy

Before generating any failed attempts, the account's lockout policy was checked, since an unplanned lockout partway through the test would itself become an uncontrolled variable. This was run from an elevated Command Prompt on the DESKTOP-AUHDFVM lab VM:

```
net accounts
```

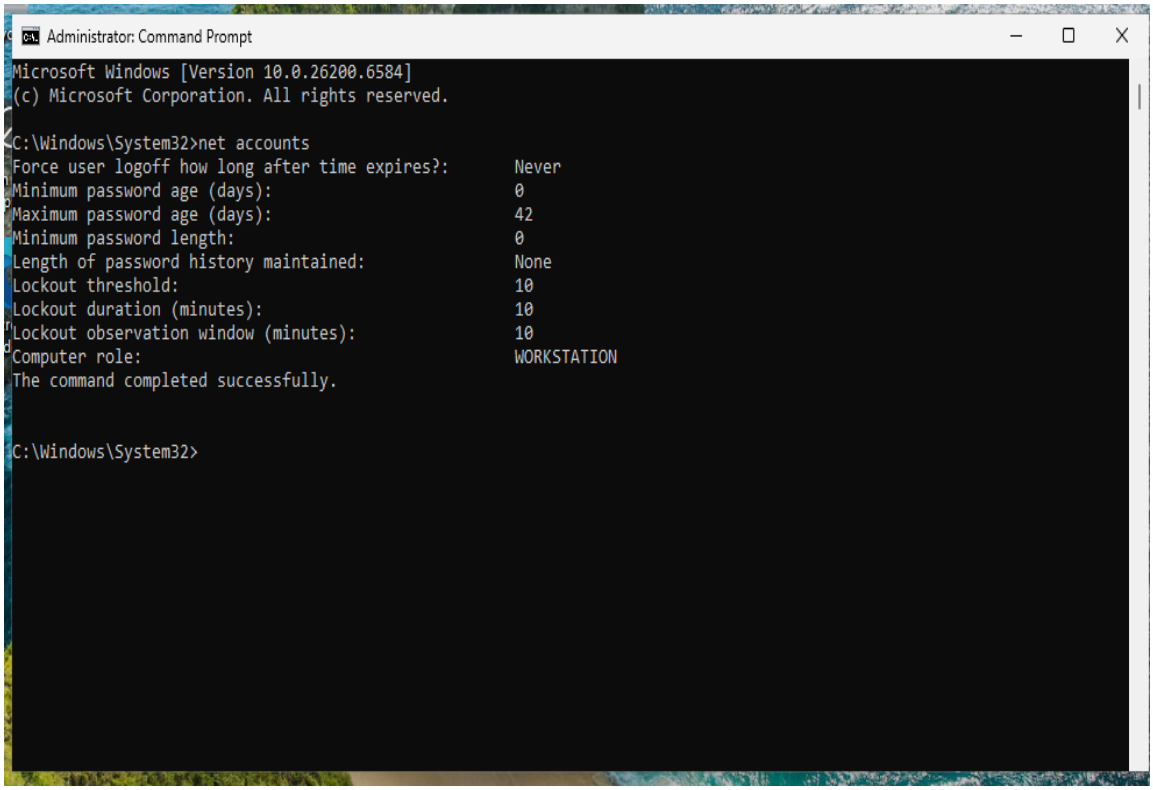


Figure 1. net accounts output on the lab VM - Lockout threshold: 10, Lockout duration: 10 minutes, Lockout observation window: 10 minutes.

With a 10-attempt threshold confirmed, eight attempts was chosen as the test size: comfortably under the lockout ceiling, while also matching Wazuh's own real rule 60204

threshold (8 occurrences within 240 seconds, verified in Day 21), so the resulting pattern could be evaluated meaningfully against an actual detection rule rather than an arbitrary number picked without a reference point.

3. Test Execution

Eight deliberate failed logon attempts were made against the CyberAmy account at the Windows lock/login screen, entering an incorrect password each time, at a controlled pace of roughly 25-45 seconds apart rather than in a rapid burst. A ninth, correct attempt was made immediately after, to confirm the account remained usable and was not locked out.

4. Investigating the Telemetry

The Security log was filtered to Event ID 4625 to isolate failed logons. The filtered list also contained several unrelated 4625 events from earlier sessions (including Day 21's own test event and other unrelated activity), which were identified and excluded by their timestamps, since only the eight events clustered together in this session's own time window belong to this test:

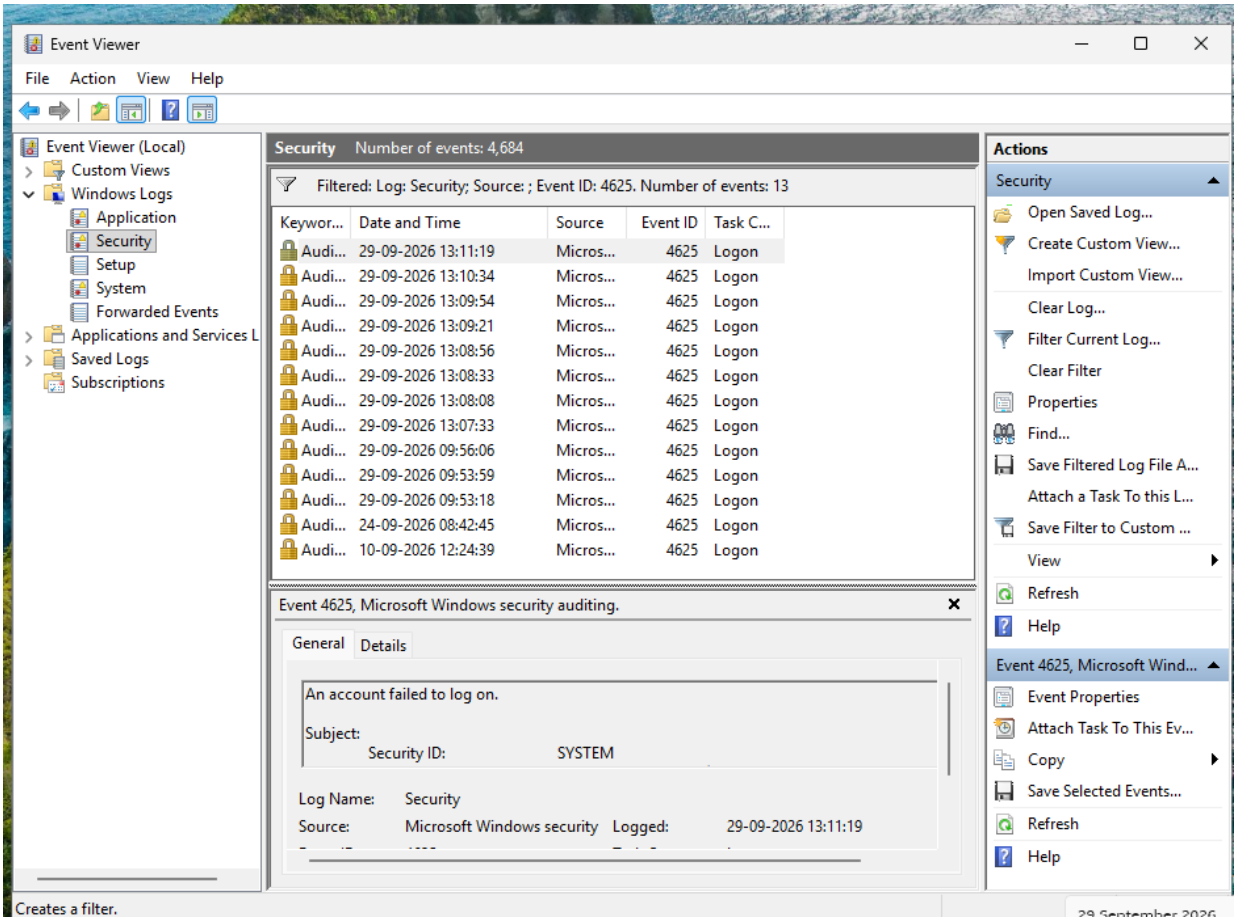


Figure 2. Security log filtered on Event ID 4625, showing the eight failed logon attempts generated for this test (13:07:33 - 13:11:19), alongside unrelated earlier events lower in the list.

The eight confirmed attempts, all against account CyberAmy, Logon Type 2 (interactive), consistent with the same failure pattern established in Day 21:

#	Timestamp	Interval from previous
1	13:07:33	-
2	13:08:08	+35s
3	13:08:33	+25s
4	13:08:56	+23s
5	13:09:21	+25s
6	13:09:54	+33s
7	13:10:34	+40s

8	13:11:19	+45s

Total elapsed time, first failure to last failure: 13:11:19 minus 13:07:33 = 3 minutes 46 seconds (226 seconds).

5. Locating the Successful Logon - A Methodology Note

Finding the correct successful-logon event was not as immediate as it first appeared, and the process itself is worth documenting, since it reflects a real, common analyst mistake rather than a clean, uneventful lookup.

- The first candidate checked, timestamped close to the last failure, turned out to show Account Name DESKTOP-AUHDFVM$ (a trailing $ denotes a computer/machine account) under that event's Subject field - a routine background logon unrelated to this test, not CyberAmy.
- A second nearby candidate showed New Logon: SYSTEM under NT AUTHORITY - also a routine background logon, and also not the event being looked for.
- Event Viewer's Find feature (searching the filtered 4624 list directly for "CyberAmy") was then used instead of continuing to open events one at a time, which correctly located the right event.

The key lesson: a Windows Event ID 4624 contains two separate account fields, Subject (who performed the logon operation, frequently SYSTEM for an interactive logon) and New Logon (who actually logged in). The very first candidate checked was in fact the correct event all along; the initial read simply stopped at the Subject field without scrolling down to the New Logon section beneath it. Re-examining that same event fully confirmed the real result:

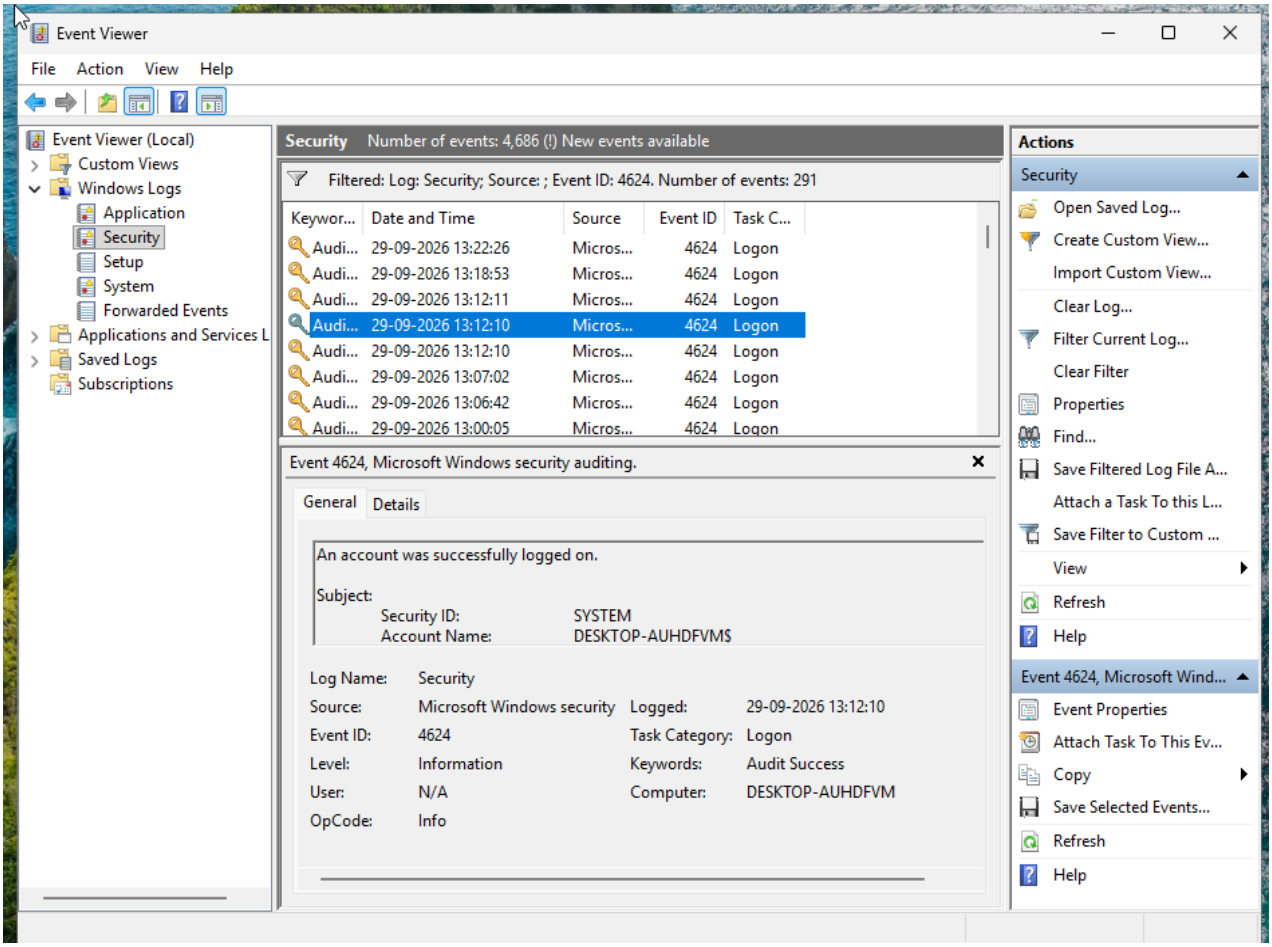


Figure 3. The same 13:12:10 event's Subject field, showing DESKTOP-AUHDFVM$ - correct, but not yet the full picture.

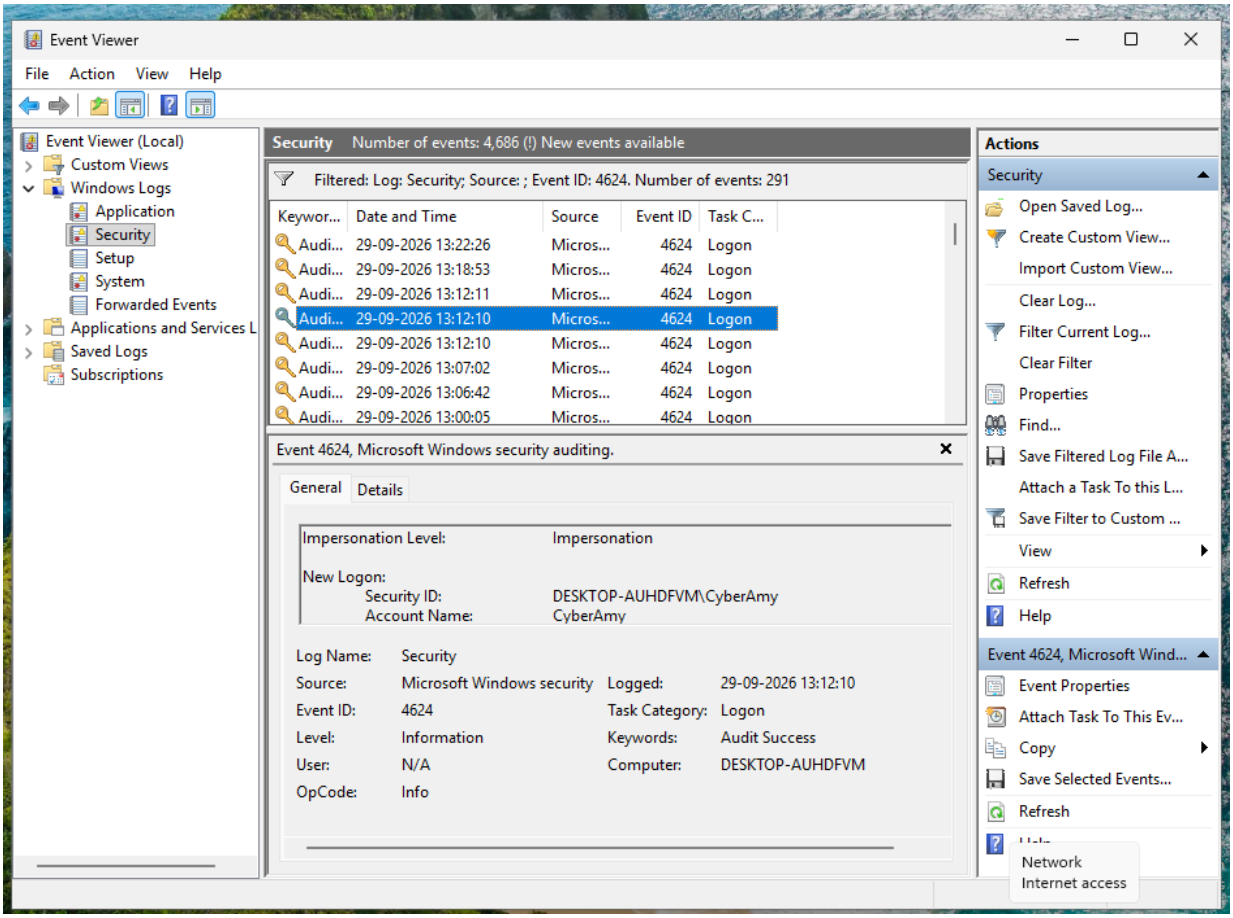


Figure 4. The same event, scrolled to New Logon - Account Name: CyberAmy, Security ID: DESKTOP-AUHDFVM\CyberAmy, confirming the successful logon at 13:12:10.

Confirmed successful logon: 29 September 2026, 13:12:10, account CyberAmy - 51 seconds after the eighth and final failed attempt.

6. Applying Wazuh's Real Correlation Rule to This Data

With a genuine, timestamped sequence in hand, Wazuh's actual rule 60204 (verified against the public ruleset in Day 21) can be applied directly rather than discussed only in the abstract:

```
<rule id="60204" level="10" frequency="$MS_FREQ" timeframe="240">
  <if_matched_group>authentication_failed</if_matched_group>
  <same_field>win.eventdata.ipAddress</same_field>
  <description>Multiple Windows Logon Failures</description>
</rule>
```

This session's eight failures: 8 occurrences within 226 seconds (inside the timeframe="240" window, with 14 seconds to spare) from the same account on the same host (satisfying the same_field correlation on source). $MS_FREQ is a ruleset-wide variable defined once in the same rules file, currently set to 8. All three conditions are met.

Conclusion: on a live Wazuh deployment, this exact sequence would have triggered rule 60204 (level 10, "Multiple Windows Logon Failures"), not merely eight isolated level-5 events. This is a directly testable prediction against this session's real data, not a hypothetical scenario.

7. Escalation Decision

Answering "should this be escalated" requires separating two questions that are easy to collapse into one: whether the rule-based threshold is met, and whether the underlying activity is actually malicious. They are not the same question, and treating them as the same is a common junior-analyst error.

- Threshold question: yes. 8 failures in 226 seconds against the same account from the same source meets Wazuh's real correlation criteria exactly, so this pattern should be escalated from the SOC tooling's perspective, and would be if a manager were live.
- Investigation question: on review, this resolves as a benign true positive, not an active compromise. Three facts support that conclusion together, not any single one alone: the source is the known lab console (not a remote or external address), the account owner is confirmed (a deliberate, self-run test), and a legitimate successful logon followed

shortly after using the correct credentials, rather than the failures simply stopping or escalating further.

The correct professional judgment is not "ignore it because it's actually fine" and not "treat it as confirmed malicious either." It is: the alert is a correct detection, closed out through investigation as expected/authorized test activity, with the reasoning documented, exactly as would be required to close any real ticket generated by this rule.

8. Evidence Summary

Test Account	CyberAmy
Host	DESKTOP-AUHDFVM
Failed Attempts	8 (Event ID 4625, Logon Type 2)
Test Window	13:07:33 - 13:11:19 (226 seconds)
Successful Logon	13:12:10 (Event ID 4624, 51 seconds after last failure)
Applicable Wazuh Rule	60204, level 10 - threshold met (8/8 required, within 226s of 240s allowed)
Escalation Verdict	Escalate per rule threshold; closed as benign true positive after investigation

9. Conclusion

This exercise was completed practically and in full on the Windows side: a real, controlled, safety-checked sequence of eight failed logons and one successful logon was generated, independently verified in Event Viewer (including correcting a genuine mid-investigation misattribution, documented rather than hidden), and analyzed against Wazuh's actual, previously-verified correlation rule. The data shows this pattern would have crossed a real brute-force detection threshold, and the report separates that rule-based fact from the investigative judgment that ultimately closes it as expected activity, which is the actual skill this task is assessing.

The one piece that remains unconfirmed in practice is the live Wazuh alert itself, since no manager is currently deployed in this lab, for the reasons documented across Days 17-20. That confirmation, a genuine rule 60204 alert generated from this exact data, will be captured once a manager is available.